



# Vulnerability Assessment and Penetration Testing Lab Report

of metasploitable vm

## 1. Overview

I planned to conduct a black-box Vulnerability Assessment and Penetration Testing (VAPT) lab exercise against target virtual machine **Metasploitable 2**. The assessment was performed from the perspective of an unauthenticated remote attacker with no prior knowledge of the target environments. The project follows a structured penetration testing methodology, including reconnaissance, scanning, enumeration, vulnerability assessment, controlled exploitation, and risk analysis. All testing activities were conducted within an authorized virtual lab environment for educational purposes and in accordance with ethical cybersecurity practices.

## 2. Objectives

- Conduct a black-box security assessment of the target virtual machines.
- Identify open ports, running services, and potential vulnerabilities.
- Perform controlled exploitation of confirmed vulnerabilities in an isolated lab.
- Evaluate the severity and potential impact of identified security weaknesses.
- Provide practical remediation recommendations to improve the security posture of the target systems.
- Document the complete assessment process, findings, and evidence in a professional VAPT report.

## 3. Methodology

The assessment followed the **Penetration Testing Execution Standard (PTES)** methodology, and all findings were rated using the **CVSS v3.1** scoring system.

| PHASES                         | FUNCTIONS                           |
|--------------------------------|-------------------------------------|
| 1. Pre-Engagement Interactions | Scope, rules, authorization         |
| 2. Intelligence Gathering      | Reconnaissance                      |
| 3. Threat Modeling             | What matters most to protect        |
| 4. Vulnerability Analysis      | Scanning, finding holes             |
| 5. Exploitation                | Actually breaking in                |
| 6. Post-Exploitation           | What can you do now that you're in? |
| 7. Reporting                   | Documenting everything              |

Tools used in mentioned phases:

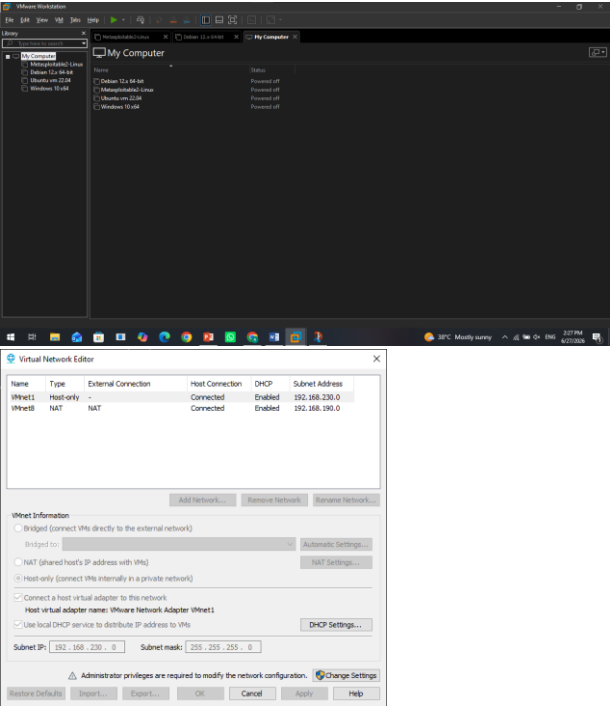
- **Intelligence Gathering:** Nmap, Netcat
- **Vulnerability Analysis:** Nmap,
- **Exploitation:** Metasploit, Netcat, manual commands
- **Post-Exploitation:** Meterpreter, LinEnum, hashdump
- **Reporting:** GitHub Markdown, CVSS v3.1 calculator

## 4. Lab-environment

| components              | details              |
|-------------------------|----------------------|
| Host Operating System   | Windows 10           |
| Virtualization Software | VMware Workstation   |
| Attacker Machine        | Kali Linux           |
| Target Machine          | Metasploitable 2     |
| Network Configuration   | NAT                  |
| Assessment Type         | Black-box            |
| Testing Environment     | Isolated Virtual Lab |

The assessment was conducted within an isolated virtual laboratory environment using VMware Workstation. Kali Linux served as the attacker machine, while Metasploitable 2 and Ubuntu were configured as target systems. The virtual machine was connected using both VMnet1 (Host-Only) and VMnet8 (NAT) networks. The Host-Only network provided an isolated environment for communication between the virtual machines, while the NAT network enabled controlled internet connectivity for updates and tool installation. This configuration provided a safe environment for performing vulnerability assessment and penetration testing without affecting production systems.

**VM Ware network contains following machines:**



**Attacker's info:**

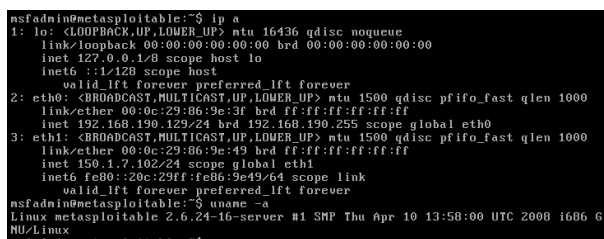
Use commands (hostname, hostname -I, cat /etc/os-release)



```
Session Actions Edit View Help
(kali123@kali123): ~
$ hostname
kali123
$ cat /etc/os-release
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2025.3"
VERSION="2025.3"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"
```

## Target info (metasploitable 2)

Use commands (hostname, ifconfig, uname -a)



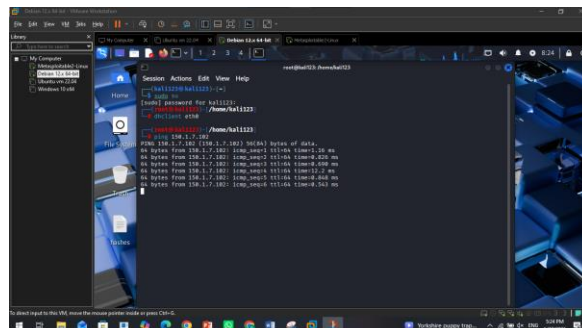
```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:86:9e:3f brd ff:ff:ff:ff:ff:ff
    inet 192.168.190.129/24 brd 192.168.190.255 scope global eth0
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:86:9e:49 brd ff:ff:ff:ff:ff:ff
    inet 150.1.7.102/24 scope global eth1
    inet6 fe80::20c:29ff:fe86:9e49/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux
```

## 5. Reconnaissance (Scanning)

### a) Network Connectivity Verification

Commands used: ping 150.1.7.102

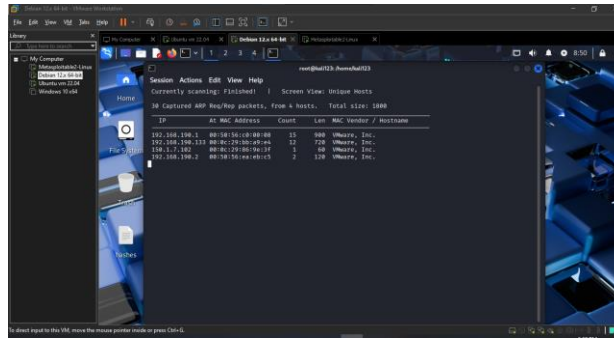
Metasploitable:



Targets is reachable

### b) Host Discovery

Commands used: netdiscover -r 150.1.7.1



target is available on network range.

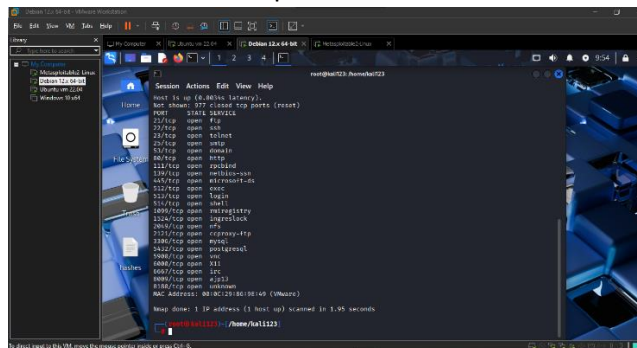
### c) ARP Cache Inspection

Commands used: arp -a

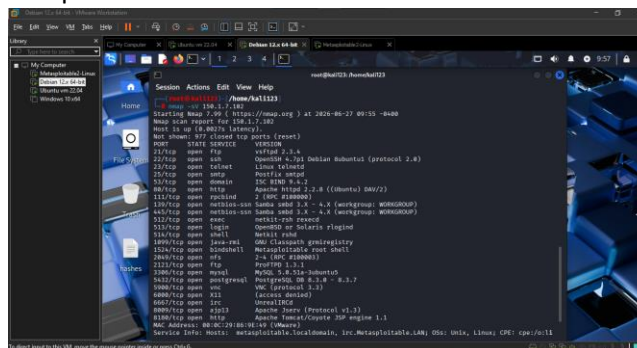
```
(root@kali123)~[/home/kali123]
# ip neigh
150.1.7.100 dev eth1 lladdr 00:50:56:c0:00:01 STALE
150.1.7.1 dev eth1 FAILED
192.168.190.133 dev eth0 lladdr 00:0c:29:bb:a9:e4 REACHABLE
150.1.7.102 dev eth1 lladdr 00:0c:29:86:9e:49 STALE
192.168.190.2 dev eth0 lladdr 00:50:56:ea:eb:c5 REACHABLE
192.168.190.254 dev eth0 lladdr 00:50:56:e6:31:0f STALE
fe80::afd5:a1b8:1be5:5ce1 dev eth1 lladdr 00:50:56:c0:00:01 STALE
```

### d) Initial Port Scanning of metasploitable

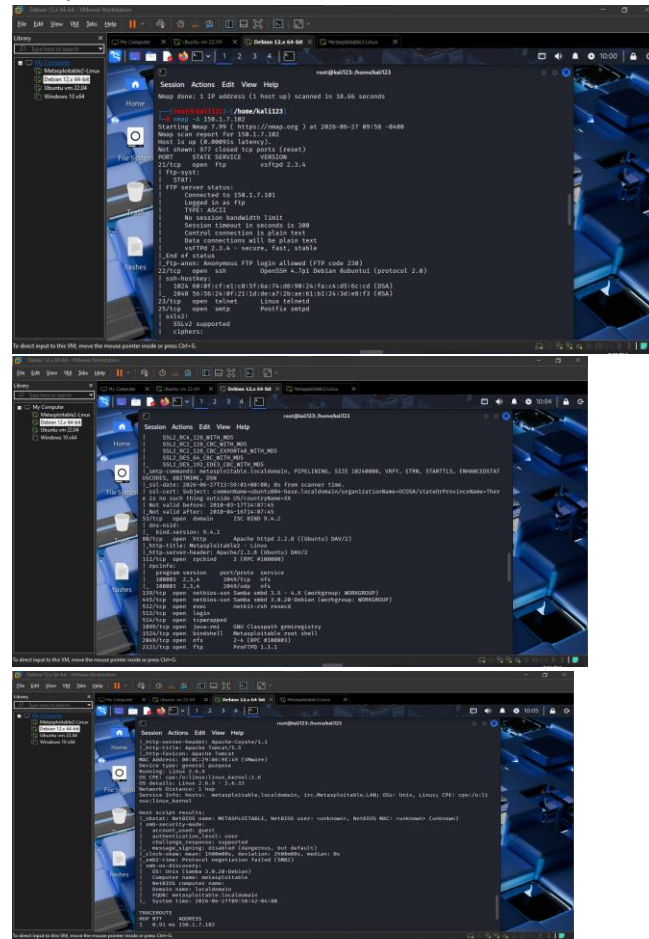
Commands used: nmap -sS 150.1.7.102



nmap -sV 150.1.7.102



## nmap -A 150.1.7.102



## 6. Enumeration

### a) FTP Enumeration (Port 21)

use commands: ftp 150.1.7.102

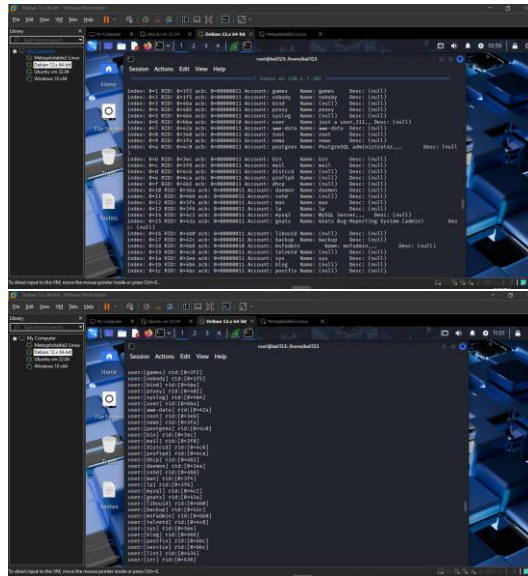
```
(root@kali123)-[/home/kali123]
# ftp 150.1.7.102
Connected to 150.1.7.102.
220 (vsFTPD 2.3.4)
Name (150.1.7.102:kali123): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||5996|).
150 Here comes the directory listing.
drwxr-xr-x  6 1000    1000    4096 Apr 28  2010 vulnerable
226 Directory send OK.
ftp>
```

Directory listing and login attempt was successful from ftp port.

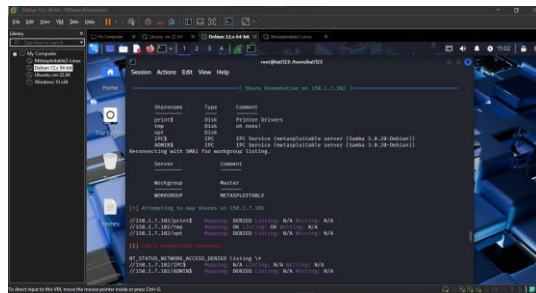
### b) SMB Enumeration (Port 139/445)

Command use: enum4linux -a 150.1.7.102

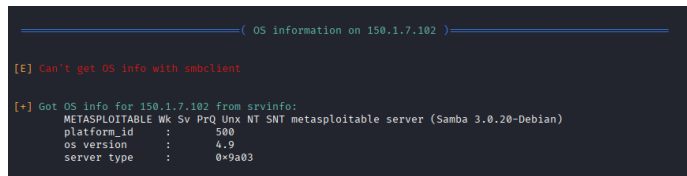
Enumerated Users:



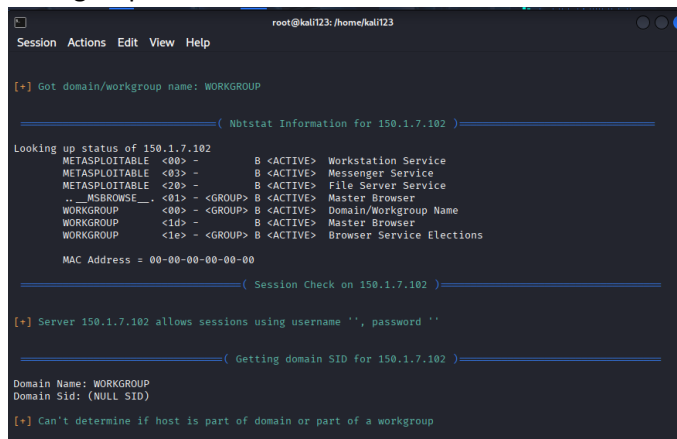
Shared folders:



OS info



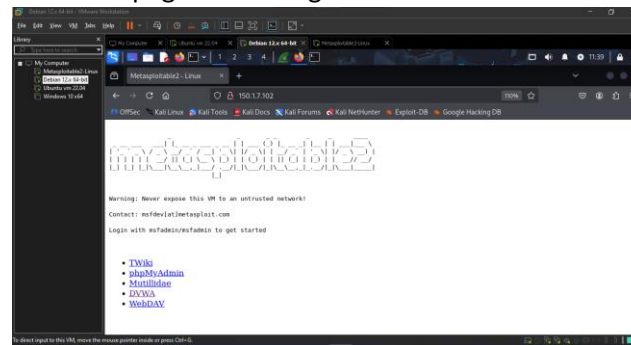
Workgroup info



c) HTTP Enumeration (Port 80)

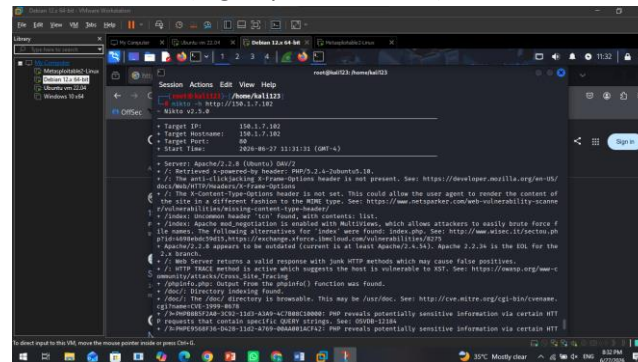
Command used: <http://150.1.7.102> for preview of webpage

The homepage of the target website



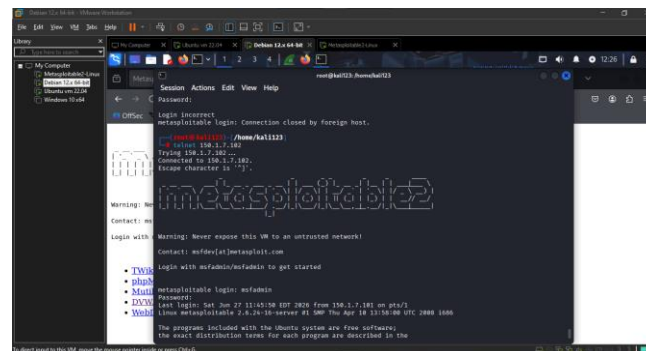
Command used: `nikto -h http://150.1.7.102`

Server banner (e.g., Apache version)



d) Telnet Enumeration (Port 23)

Command used `telnet 150.1.7.102`



## 7. Post-Enumeration

- Run an Nmap Vulnerability Scan  
Command used: `nmap --script vuln 150.1.7.102`
- Web Server Assessment  
Command used: `nikto -h http://150.1.7.102`
- Search for Public Exploits  
Command used: `searchsploit <service_name>`
- Review Service Versions
- Findings Table



## 8. Findings

The vulnerability assessment and penetration testing exercise identified multiple security weaknesses on the Metasploitable 2 target system. Network reconnaissance revealed numerous open ports exposing services such as FTP, Telnet, HTTP, SMB, SSH, SMTP, and database services. Service enumeration confirmed that several applications were outdated and matched publicly documented vulnerabilities.

Anonymous FTP access was enabled, allowing unauthenticated users to access the FTP service. SMB enumeration disclosed user accounts, shared resources, and operating system information, providing valuable intelligence for potential attackers. The Telnet service accepted remote connections, transmitting authentication data without encryption and increasing the risk of credential compromise. Web server assessment using Nikto identified outdated Apache components, insecure HTTP configurations, and other web server misconfigurations.

Vulnerability scanning and public exploit research confirmed that several detected services had known exploits available in public exploit databases. Controlled exploitation within the isolated laboratory environment successfully demonstrated that vulnerable services could be compromised, validating the identified security weaknesses. Post-exploitation activities further confirmed the ability to gather system information and assess the potential impact of a successful attack.

Overall, the assessment demonstrated that the target system contains intentionally vulnerable configurations suitable for security training. In a production environment, these weaknesses would present a significant risk to the confidentiality, integrity, and availability of organizational assets.

## 9. Risk analysis

The overall risk level of the assessed target is critical due to the presence of multiple high-impact vulnerabilities and insecure services. Several exposed services were running outdated software versions with publicly available exploits, significantly reducing the effort required for an attacker to gain unauthorized access.

The combination of anonymous FTP access, unsecured Telnet communication, vulnerable SMB services, and outdated web server software increases the attack surface and provides multiple paths for compromise. Successful exploitation of these vulnerabilities could result in unauthorized access, information disclosure, privilege escalation, service disruption, and complete system compromise.

Although the assessment was performed within an isolated laboratory environment designed for educational purposes, similar vulnerabilities in a production environment could lead to severe business impacts, including data breaches, operational downtime, reputational damage, and financial loss. The findings emphasize the importance of timely patch management, secure service configuration, network segmentation, strong authentication mechanisms, and regular vulnerability assessments to reduce organizational risk.

| <b>Findings</b>                            | <b>Severity</b> | <b>Potential Impact</b>     | <b>Risk Level</b> |
|--------------------------------------------|-----------------|-----------------------------|-------------------|
| <b>Anonymous Ftp Access</b>                | Medium          | Unauthorized File Access    | Medium            |
| <b>Telnet Service Enabled</b>              | High            | Credential Interception     | High              |
| <b>Outdated Apache Web Server</b>          | High            | Remote Exploitation         | High              |
| <b>Smb Information Disclosure</b>          | High            | User And System Enumeration | High              |
| <b>Publicly Available Service Exploits</b> | Critical        | Remote Code Execution       | Critical          |
| <b>Multiple Open Network Services</b>      | Medium          | Increased Attack Surface    | Medium            |